Phụ lục: Kế hoạch cập nhật VietQR cho Web POS & Quản lý kho (Laravel)

Bản 02/11/2026. Phụ lục này nối tiếp Phụ lục kế hoạch giai đoạn 2 (mục 6, Pha 13b) và README mục 4.3, 4.4. Nội dung gồm cập nhật cách tạo mã VietQR bằng lớp **VietQrService** (Pha 13a) và thiết kế webhook tự xác nhận (Pha 13b). Chức năng không thuộc phạm vi demo ngày 05/11/2026 nếu chưa kịp; phần tạo QR thủ công đã dùng được. Các sơ đồ đánh số S33, S34, test từ T61, truy vấn SQL số 14, để không trùng với hồ sơ chính và phụ lục giai đoạn 2.

1. Tổng quan và thứ tự ưu tiên

1.1 Bảng hạng mục

Ước lượng công sức là con số thô cho 1 người, chỉ để xếp thứ tự, cần điều chỉnh khi bắt tay làm.

#	Hạng mục	Hiện trạng	Phụ thuộc	Công sức	Rủi ro	Pha
1	Tạo QR bằng VietQrService, cấu hình trong config/pos.php	Đã có QR trong POS, cần gom về một lớp dịch vụ	Pha 3	0,5 ngày	Thấp	13a
2	Xác nhận chuyển khoản thủ công	Đã có	Pha 13a	—	Thấp: dễ nhầm nếu không kiểm tra ngân hàng	13a
3	Webhook tự xác nhận (SePay, Casso, payOS hoặc tương đương)	Chưa	Pha 13a	2 ngày	Trung bình: cần tài khoản dịch vụ, sandbox	13b
4	Nhật ký giao dịch và đối soát	Chưa	Pha 13b, 17	0,5 ngày	Thấp	13b

1.2 Thứ tự làm đề xuất

1. **VietQrService** và cấu hình, vì rẻ và dùng được ngay cho demo.
2. Kiểm thử đơn vị cho dịch vụ (T61 đến T64), rồi mới gắn vào màn hình POS.
3. Xác nhận thủ công giữ nguyên làm phương án dự phòng.
4. Webhook (Pha 13b) chỉ làm sau khi chốt nhà cung cấp có sandbox, tài liệu API và chữ ký webhook.

2. Tạo mã VietQR (Pha 13a)

2.1 Quy tắc nghiệp vụ

- Mã VietQR là ảnh do dịch vụ **img.vietqr.io** sinh ra từ mã ngân hàng, số tài khoản, số tiền và nội dung; không cần khóa API.
- Số tiền do server tính từ giỏ hàng (`tong_thanh_toan`, đã trừ giảm giá và điểm); không nhận số tiền từ trình duyệt.
- Nội dung chuyển khoản là mã hóa đơn, tự bỏ dấu tiếng Việt và ký tự đặc biệt, cắt tối đa 25 ký tự.
- Chưa cấu hình, cấu hình sai định dạng hoặc số tiền ≤ 0 thì không hiển thị QR (hàm trả về `null`).
- **QR không tự biết giao dịch đã thành công.** Thu ngân chỉ xác nhận sau khi thấy giao dịch trong ứng dụng ngân hàng hoặc sao kê; không tin ảnh chụp màn hình của khách.
- Ảnh QR tải từ bên ngoài nên cần có mạng khi demo; luôn có phương án chuyển khoản thủ công hoặc tiền mặt dự phòng.
- Chỉ dùng tài khoản demo hoặc tài khoản do chủ dự án cho phép; không commit file `.env`.

2.2 Tham số URL

```
https://img.vietqr.io/image/{BANK}-{SO_TAI_KHOAN}-{TEMPLATE}.png
    ?amount=197000&addInfo=HD202611020001&accountName=TEN%20CHU%20TAI%20KHOAN
```

Tham số	Ý nghĩa	Ghi chú
BANK	Mã ngân hàng	VCB, TCB, MB, ACB… hoặc BIN 6 số; hợp lệ khi gồm 2 đến 10 chữ và số
SO_TAI_KHOAN	Số tài khoản nhận	Chỉ gồm chữ số, 6 đến 19 ký tự
TEMPLATE	Kiểu hiển thị ảnh	compact, compact2 (mặc định), qr_only, print; giá trị khác tự về compact2
amount	Số tiền	Số nguyên dương, không dấu phân cách
addInfo	Nội dung chuyển khoản	Mã hóa đơn, không dấu, tối đa 25 ký tự
accountName	Tên chủ tài khoản	Tùy chọn; bỏ dấu và viết hoa

2.3 Cấu hình

```
# .env (không commit)
POS_BANK_CODE=VCB
POS_BANK_ACCOUNT=0123456789
POS_BANK_NAME="TEN CHU TAI KHOAN"
POS_QR_TEMPLATE=compact2

// config/pos.php (thêm vào m□ng hiện có)
'bank_code'    => env('POS_BANK_CODE'),
'bank_account' => env('POS_BANK_ACCOUNT'),
'bank_name'    => env('POS_BANK_NAME'),
'qr_template'  => env('POS_QR_TEMPLATE', 'compact2'),
```

Sau khi sửa `.env` chạy `php artisan config:clear`.

2.4 Lớp VietQrService

Đặt tại `app/Services/VietQrService.php`. Ba hàm chính:

Hàm	Chức năng
enabled(): bool	Kiểm tra mã ngân hàng và số tài khoản đã cấu hình đúng định dạng
url(int $amount, string $noiDung): ?string	Trả về URL ảnh QR, hoặc null nếu chưa cấu hình hoặc số tiền không hợp lệ
cleanNoiDung(string $text): string	Bỏ dấu, bỏ ký tự đặc biệt, gộp khoảng trắng, cắt 25 ký tự

```
public function url(int $amount, string $noiDung): ?string
{
    if (! $this->enabled() || $amount <= 0) return null;

    $template = config('pos.qr_template', 'compact2');
    if (! in_array($template, self::TEMPLATES, true)) $template = 'compact2';

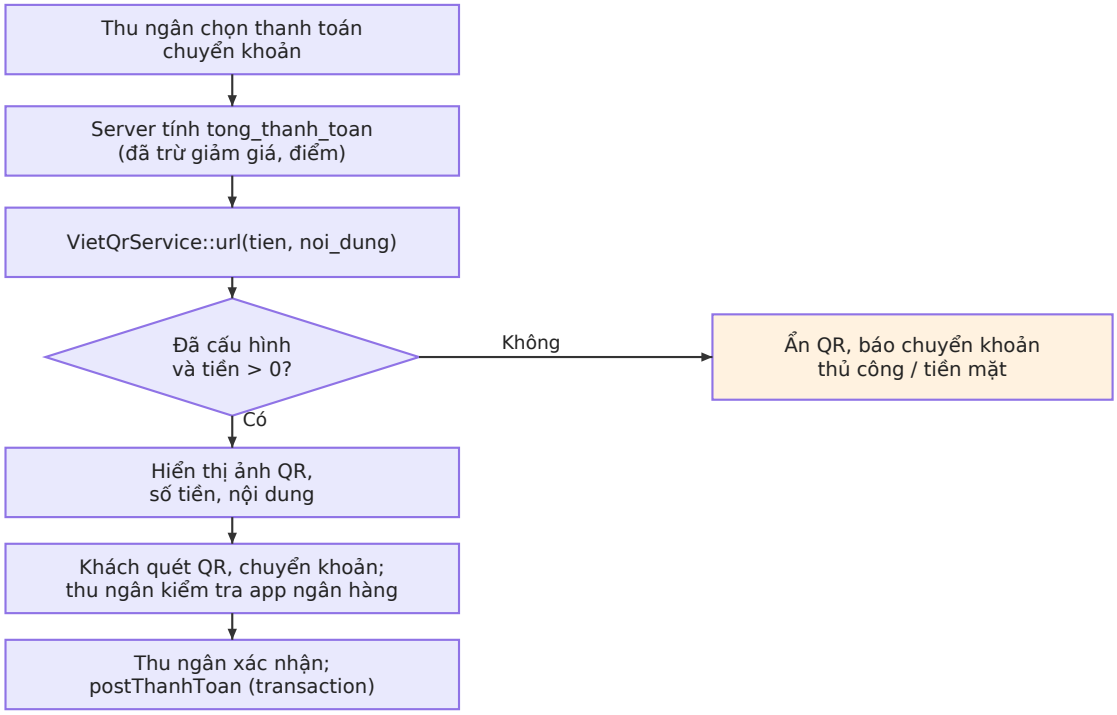
    $query = ['amount' => $amount, 'addInfo' => self::cleanNoiDung($noiDung)];
    $name  = trim((string) config('pos.bank_name'));
    if ($name !== '') $query['accountName'] = Str::upper(Str::ascii($name));

    return sprintf('https://img.vietqr.io/image/%s-%s-%s.png?%s',
        config('pos.bank_code'), config('pos.bank_account'), $template,
        http_build_query($query, '', '&', PHP_QUERY_RFC3986));
}
```

2.5 Hiển thị trên POS

Route `pos.vietqr` (GET /pos/vietqr, quyền admin và thungan) gọi `PosController@getVietQr`. Hàm này lấy tổng thanh toán từ giỏ hàng trên server, gọi `VietQrService::url` rồi trả về view `pos/_vietqr.blade.php`, hiển thị ảnh QR, số tiền, nội dung và cảnh báo thu ngân phải kiểm tra ngân hàng. Nếu ảnh không tải được, view hiện thông báo lỗi và hướng dẫn chuyển khoản thủ công.

S33. Luồng hiển thị VietQR và xác nhận thủ công



3. Webhook xác nhận thanh toán (Pha 13b)

Webhook không thể tự triển khai chỉ bằng tài khoản ngân hàng thông thường; cần dịch vụ đối soát có API hoặc webhook (SePay, Casso, payOS hoặc tương đương). Thiết kế dưới đây giữ nguyên hướng của hồ sơ chính (mục 2.7, sơ đồ S17, S18) và README mục 4.4.

3.1 Dữ liệu

Bảng, cột	Ghi chú
invoices.ma_giao_dich	varchar 40, UNIQUE, nullable; mã ngẫu nhiên khó đoán, không dùng mã hóa đơn dễ đoán
invoices.trang_thai	thêm giá trị cho_xac_nhan (đã lập hóa đơn, chờ tiền về) trước da_thanh_toan
payment_webhooks.id	khóa chính
payment_webhooks.nha_cung_cap	varchar 30: sepay, casso, payos…
payment_webhooks.ma_giao_dich_ngoai	varchar 80, UNIQUE; mã giao dịch của nhà cung cấp, dùng chống xử lý trùng
payment_webhooks.invoice_id	FK invoices.id, nullable (webhook không khớp hóa đơn vẫn được ghi log)
payment_webhooks.so_tien, ket_qua	số tiền nhận; ket_qua: thanh_cong, sai_so_tien, khong_khop, sai_chu_ky, trung
payment_webhooks.created_at	thời điểm nhận; không lưu secret và không lưu toàn bộ payload nhạy cảm

3.2 Quy trình xử lý

1. Nhà cung cấp gọi `POST /api/webhook/thanhtoan` (HTTPS, không qua middleware đăng nhập, không cần CSRF).
2. Xác thực chữ ký hoặc secret của nhà cung cấp **trước khi đọc payload**; sai thì trả 401 và ghi log `sai_chu_ky`.
3. Mở `DB::transaction`; kiểm tra `ma_giao_dich_ngoai` đã có chưa. Đã có thì trả 200 và ghi `trung`, không xử lý lại (idempotent).
4. Tìm hóa đơn `cho_xac_nhan` theo mã giao dịch trong nội dung chuyển khoản, khóa dòng bằng `lockForUpdate`.
5. Đối chiếu số tiền bằng `tong_thanh_toan`, ngân hàng nhận và trạng thái giao dịch; sai thì ghi `sai_so_tien`, không đổi trạng thái.

6 Hợp lệ thì chuyển hóa đơn sang `da_thanh_toan`, trừ kho và cộng điểm như thanh toán tại quầy (dùng lại lớp nghiệp vụ hiện có), ghi `activity_logs`.
7 COMMIT, trả 200 cho nhà cung cấp; các việc chậm (in, gửi tin) đẩy vào hàng đợi, không chạy trong transaction.

3.3 Lưu ý an toàn

- Không mở endpoint webhook không xác thực và không tin dữ liệu do trình duyệt gửi lên.
- Không ghi secret hay toàn bộ thông tin nhạy cảm vào log; chỉ giữ mã giao dịch, trạng thái và thời điểm.
- Kiểm thử trên sandbox: webhook gửi lặp, sai chữ ký, sai số tiền, timeout, trước khi dùng production.
- Luôn giữ nút xác nhận thủ công cho trường hợp dịch vụ đối soát chậm hoặc lỗi.
- Cần đọc tài liệu hiện hành của nhà cung cấp; có thể phát sinh chi phí hoặc cần duyệt trước.

4. Kiểm thử và kiểm tra nhất quán

4.1 Kịch bản kiểm tra bổ sung

ID	Tình huống	Cách thử	Kết quả đúng	Nếu sai thì nghi ngờ
T61	Tạo URL đúng định dạng	Cấu hình VCB, số tiền 197000, nội dung HD2026-0001	URL gồm VCB-số tài khoản-compact2, amount=197000, addInfo=HD20260001	Sai thứ tự đường dẫn hoặc quên bỏ dấu gạch
T62	Chưa cấu hình	Để trống POS_BANK_CODE	url() trả null, POS ẩn QR và báo chưa cấu hình	Hiện ảnh lỗi hoặc ném ngoại lệ
T63	Số tiền không hợp lệ	Truyền 0 hoặc số âm	Trả null	Thiếu kiểm tra số tiền
T64	Làm sạch nội dung	Nội dung "Thanh toán hóa đơn!!" dài 60 ký tự	Không dấu, không ký tự đặc biệt, ≤ 25 ký tự	Quên Str::ascii hoặc quên cắt độ dài
T65	Số tiền lấy từ server	Sửa số tiền trong request	QR vẫn theo tong_thanh_toan của giỏ	Tin dữ liệu từ trình duyệt
T66	Webhook trùng	Gửi hai lần cùng ma_giao_dich_ngoai	Chỉ xử lý một lần, lần hai ghi trung	Thiếu UNIQUE hoặc kiểm tra trùng
T67	Sai chữ ký hoặc sai số tiền	Gửi webhook giả, rồi gửi thiếu tiền	Hóa đơn giữ nguyên cho_xac_nhan, có log	Không xác thực chữ ký hoặc không so số tiền
T68	Webhook sau khi thu ngân đã xác nhận thủ công	Xác nhận tay rồi gửi webhook đúng	Không trừ kho hai lần	Không kiểm tra trạng thái trước khi xử lý

4.2 Truy vấn SQL kiểm tra nhất quán bổ sung

Truy vấn dưới đây phải trả về 0 dòng. Truy vấn 14 giả định đã có bảng `payment_webhooks` ở Pha 13b.

```
-- 14. Moi ma giao dich ngoai chi duoc xu ly thanh cong mot lan
SELECT w.ma_giao_dich_ngoai
FROM payment_webhooks w
WHERE w.ket_qua = 'thanh_cong'
GROUP BY w.ma_giao_dich_ngoai
HAVING COUNT(*) > 1;
```

5. Quy ước Copilot bổ sung và bộ prompt Pha 13a, 13b

Thêm vào mục 8 của `.github/copilot-instructions.md`:

```
## 10. Quy ước VietQR
- Tạo QR chỉ qua App\Services\VietQrService, không dựng URL trong view hoặc JavaScript.
- Số tiền do server tính, nội dung dùng mã hóa đơn đã làm sạch (tối đa 25 ký tự).
- QR không phải bằng chứng thanh toán; chỉ chuyển da_thanh_toan sau khi xác nhận thủ công
  hoặc webhook đã xác thực chữ ký, khớp số tiền và mã giao dịch.
- Webhook phải idempotent, ghi payment_webhooks, không ghi secret vào log.
```

Pha 13a: VietQR

@workspace Đọc copilot-instructions.md mục 10 và mục 2 của phụ lục VietQR. Tạo VietQrService (enabled, url, cleanNoiDung), thêm khóa bank_code, bank_account, bank_name, qr_template vào config/pos.php, view pos/_vietqr.blade.php và route pos.vietqr. Số tiền lấy từ giỏ hàng trên server. Viết VietQrServiceTest. Kiểm tra: T61 đến T65.

Pha 13b: Webhook

@workspace Tạo migration payment_webhooks và cột invoices.ma_giao_dich, trạng thái cho_xac_nhan. Tạo PaymentWebhookController@postThanhToan tại POST /api/webhook/thanhtoan: xác thực chữ ký trước khi đọc payload, DB::transaction, kiểm tra trùng ma_giao_dich_ngoai, lockForUpdate hóa đơn, so số tiền, chuyển da_thanh_toan bằng lớp nghiệp vụ thanh toán hiện có, ghi payment_webhooks và activity_logs. Theo mục 3 của phụ lục. Kiểm tra: T66 đến T68, SQL 14.

6. Đề xuất lộ trình

Giai đoạn	Nội dung	Kết quả cần đạt
Trước demo 05/11	Pha 13a: VietQrService, cấu hình, view POS	QR hiển thị đúng số tiền, T61 đến T65 đạt, có phương án thủ công dự phòng
Sau demo, tuần 1	Chọn nhà cung cấp đối soát, đăng ký sandbox	Có tài liệu API, secret và cách xác thực chữ ký
Sau demo, tuần 2	Pha 13b: webhook, payment_webhooks, nhật ký	T66 đến T68 và SQL 14 đạt trên sandbox
Sau đó	Chạy production với tài khoản thật	Chỉ làm sau khi test sai chữ ký, sai số tiền và timeout